

Política de Retenção, Descarte e Backup

Uso operacional e controles LGPD

Sistema Clínico MVP

VERSÃO	1.0
EMIÇÃO	13 de agosto de 2026
CLASSIFICAÇÃO	Uso interno
STATUS	Minuta técnico-operacional

CONDIÇÃO DE VIGÊNCIA

Os prazos e as automações destrutivas dependem de validação do Controlador, DPO, jurídico/regulatório e responsável assistencial. Este documento não representa declaração de conformidade plena com a LGPD.

Alerta obrigatório antes da produção: os prazos e procedimentos deste documento devem ser validados pelo Controlador, pelo Encarregado/DPO, pela assessoria jurídica, pelos responsáveis assistenciais e, quando aplicável, pela área regulatória antes de serem ativados em produção. Esta política organiza controles técnicos e operacionais, mas não representa declaração de conformidade plena com a LGPD, nem substitui análise jurídica, regulatória ou de guarda de prontuário.

1. Finalidade

Esta política estabelece critérios para:

- proteger a disponibilidade e a recuperabilidade do banco MySQL;
- limitar a retenção de backups, logs técnicos, registros de integração, itens concluídos da fila de sincronização, auditorias e espelhos operacionais;
- impedir o descarte automático de registros clínicos que exigem análise jurídica, regulatória e assistencial específica;
- definir responsabilidades, aprovações, evidências e resposta a falhas;
- apoiar os princípios de finalidade, necessidade, segurança, prevenção e responsabilização previstos na LGPD.

Os prazos aqui definidos são parâmetros de governança e operação. Eles não autorizam a eliminação quando existir obrigação legal ou regulatória, ordem judicial, investigação, incidente, solicitação formal de preservação ou outra hipótese de retenção devidamente registrada.

2. Escopo

Esta política aplica-se aos ambientes administrados para o Sistema Clínico MVP, especialmente:

- banco MySQL executado pelo serviço mysql do Docker Compose;
- backups do banco MySQL;
- logs dos contêineres Docker;
- tabelas logs_integracao, fila_sincronizacao e auditorias;
- espelhos locais MED_SPDATA_AGENDA e MED_SPDATA_ATENDIMENTOS;
- registros de Atendimento, Anamnese, Evolução Médica e suas versões, Diagnóstico, Prescrição, Solicitação de Exame e Documento Médico;
- infraestrutura de VPS, mídia ou repositório utilizado para backup;
- ambiente isolado usado nos testes de restauração.

Referências operacionais do repositório:

- docs/DEPLOY_DOCKER_VPS.md;
- docker-compose.yml;
- .env.example;
- scripts/backup_mysql_encrypted.sh;
- scripts/restore_mysql_encrypted.sh.

3. Situação técnica verificada e condição de uso

Na revisão do repositório realizada para esta versão do documento:

- o deploy utiliza MySQL 8.4 em volume Docker persistente;
- docs/DEPLOY_DOCKER_VPS.md orienta o uso dos scripts criptografados de backup e restauração;
- os modelos das tabelas abrangidas possuem campos temporais utilizáveis para seleção de retenção;
- o comando Flask lgpd-retencao implementa simulação (--dry-run) e execução (--execute) da lista fechada de tabelas desta política, com proteção de referências conhecidas e registro de auditoria da execução;
- o docker-compose.yml contém configuração explícita de rotação 10x10MB para os cinco serviços;
- scripts/backup_mysql_encrypted.sh gera dump compactado, criptografado com age, acompanhado de SHA-256 e retenção configurável;
- scripts/restore_mysql_encrypted.sh exige e valida o SHA-256, exige confirmação deliberada e restaura o conteúdo por fluxo, sem persistir SQL em claro.

Esses controles ainda devem ser configurados, revisados e testados no ambiente de destino antes da ativação em produção. A existência dos controles técnicos não substitui as aprovações previstas nesta política.

4. Papéis e responsabilidades

4.1 Controlador

Compete ao Controlador:

- definir e documentar as finalidades do tratamento;
- aprovar os prazos de retenção e as hipóteses de descarte;
- assegurar a participação das áreas jurídica, regulatória e assistencial;
- decidir sobre exceções, preservações legais e descarte de dados clínicos;
- disponibilizar recursos para backup, monitoramento e testes de restauração;
- aprovar formalmente esta política e suas revisões.

4.2 Encarregado/DPO

Compete ao Encarregado/DPO:

- orientar o Controlador e a TI quanto aos efeitos de proteção de dados;
- acompanhar solicitações de titulares sem determinar exclusão direta no banco;
- verificar se a finalidade, a necessidade e os prazos permanecem adequados;
- participar da avaliação de incidentes, exceções e preservações;
- acompanhar as evidências de descarte, falhas e testes de restauração;
- registrar seu parecer nas revisões da política.

4.3 Tecnologia da Informação — TI

Compete à TI:

- implementar os controles aprovados sem alterar unilateralmente os prazos;
- proteger credenciais, chaves, backups e evidências;
- executar backups, validações, dry-runs, descartes e restaurações conforme este procedimento;
- aplicar menor privilégio aos acessos administrativos;
- monitorar falhas, capacidade, integridade e execução do cron;
- manter evidências técnicas sem incluir conteúdo clínico ou credenciais;
- interromper a operação e escalar ao Controlador e ao DPO quando houver inconsistência, risco de perda ou impedimento referencial.

5. Matriz oficial de retenção e descarte

Ativo ou conjunto de dados	Prazo/regra	Marco para contagem	Ação ao final	Observações obrigatórias
Backups MySQL criptografados com age	30 dias	Data e hora UTC de criação do backup	Eliminação automática do arquivo criptografado e de seu checksum	A limpeza somente ocorre depois de um novo backup válido. A chave privada não pode permanecer na VPS.
Logs Docker	Rotação 10x10MB	Tamanho de cada arquivo	Rotação por tamanho	É limite técnico, não prazo temporal. Corresponde a até dez arquivos de 10 MB por contêiner, aproximadamente 100 MB por contêiner.
logs_integracao	180 dias	created_at	Exclusão dos registros vencidos	Pode conter payloads operacionais; não registrar credenciais ou conteúdo sensível desnecessário. A exclusão desta cópia local não elimina a fonte SPData nem o prontuário.
fila_sincronizacao com status SINCRONIZADO ou CANCELADO	90 dias	updated_at	Exclusão dos itens vencidos	O payload pode conter conteúdo clínico já sincronizado; a execução exige confirmação de sincronização terminal. Itens PENDENTE, PROCESSANDO ou ERRO não são eliminados.
auditorias	5 anos	created_at	Exclusão dos registros vencidos	Preservações formais suspendem o descarte dos registros abrangidos. A evidência do expurgo deve ficar fora da própria tabela eliminada.
MED_SPDATA_AGENDA	2 anos	data_agenda	Monitoramento, sem exclusão automática nesta versão	O dry-run contabiliza o prazo, mas o execute preserva o espelho até homologação de FKs e concorrência no MySQL.
MED_SPDATA_ATENDIMENTOS	2 anos	data_atendimento	Monitoramento, sem exclusão automática nesta versão	O dry-run contabiliza o prazo e vínculos lógicos; dependências e concorrência devem ser saneadas antes da automação.

Atendimento	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Exige validação jurídica, regulatória e assistencial.
Anamnese	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Aplica-se ao conteúdo clínico associado ao atendimento.
Evolução Médica e versões	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Inclui evolucoes_medicas e evolucoes_medicas_versoes.
Diagnóstico	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Inclui informações de CID e diagnóstico descritivo.
Prescrição	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Inclui medicamentos, dosagens e orientações.
Solicitação de exame	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	O status cancelado da solicitação não autoriza descarte automático.
Documento médico	Sem descarte automático	Não se aplica	Somente por procedimento específico aprovado	Inclui documentos estruturados e eventuais arquivos associados.

“Sem descarte automático” não significa retenção perpétua definida por esta política. Significa que nenhum job, cron, script genérico, cascata intencional ou comando administrativo pode eliminar esses registros com base apenas em idade. Qualquer descarte deve resultar de procedimento próprio, com fundamento validado, escopo identificado, aprovação formal, avaliação de vínculos, backup aplicável e evidência auditável.

6. Pré-requisitos operacionais

Antes de ativar backup, restauração ou descarte, a TI deve confirmar:

1. política aprovada e prazos validados jurídica e regulatoriamente;
2. Docker Engine e Docker Compose operacionais;
3. serviço mysql saudável e banco identificado corretamente;
4. utilitários age, age-keygen, gzip e sha256sum instalados no ambiente apropriado;
5. espaço disponível para o dump e para a retenção de 30 dias;
6. diretório de backup com acesso restrito;
7. relógio do host sincronizado e operação registrada em UTC;
8. destinatário público age configurado na VPS;
9. chave privada age guardada fora da VPS e recuperável por pessoas autorizadas;
10. scripts revisados, versionados, testados e com permissões restritas;
11. ambiente isolado disponível para o teste trimestral de restauração;
12. canal de alerta e responsável de plantão ou escalonamento definidos;
13. preservações legais, investigações e exceções verificadas antes de qualquer descarte;
14. backup válido concluído antes da execução de retenção no banco.

Verificações iniciais:

```
docker --version
docker compose version
age --version
age-keygen --version
gzip --version
sha256sum --version
docker compose ps
docker compose exec -T mysql sh -c 'mysqladmin ping -h 127.0.0.1 -uroot -p"$MYSQL_ROOT_PASSWORD"'
```

7. Geração e guarda da chave age

7.1 Regra de separação

A chave privada age não deve ser gerada, copiada ou mantida na VPS de produção. A VPS precisa apenas do destinatário público, que pode ser usado para criptografar, mas não para descriptografar os backups.

7.2 Geração em estação confiável e fora da VPS

Executar em equipamento administrativo confiável, preferencialmente isolado e sob controle institucional:

```
umask 077
age-keygen -o medsystem-backup.agekey
age-keygen -y medsystem-backup.agekey > medsystem-backup.recipient
chmod 600 medsystem-backup.agekey
chmod 644 medsystem-backup.recipient
```

- medsystem-backup.agekey é a identidade privada e deve permanecer fora da VPS.
- medsystem-backup.recipient contém o destinatário público que será configurado na VPS.
- O conteúdo real da chave privada não deve ser incluído em ticket, e-mail, log, .env, repositório Git ou documento.

7.3 Custódia

A identidade privada deve ser mantida em cofre de segredos, mídia corporativa criptografada ou mecanismo institucional equivalente, com acesso nominal, autenticação forte e cópia de recuperação controlada. O Controlador deve nomear os custodiantes. Todo acesso, cópia, recuperação, rotação ou revogação deve ser registrado.

A perda da chave privada torna os backups inacessíveis. A suspeita de exposição exige contenção, avaliação de incidente, geração de novo par e planejamento de rotação. Backups antigos continuam dependentes da chave usada em sua criação até o término da retenção ou recriptografia formalmente aprovada.

8. Configuração de ambiente

As variáveis abaixo devem ser configuradas no ambiente operacional do backup. O destinatário age é público; senhas MySQL continuam protegidas pelo .env de produção e não devem ser repetidas em scripts, crons ou logs.

```
BACKUP_DIR=/var/backups/sistema-clinico-mvp/mysql
BACKUP_RETENTION_DAYS=30
BACKUP_AGE_RECIPIENT=age1SUBSTITUIR_PELO_DESTINATARIO_PUBLICO

LGPD_RETENTION_LOGS_INTEGRACAO_DAYS=180
LGPD_RETENTION_FILA_SINCRONIZACAO_DAYS=90
LGPD_RETENTION_AUDITORIA_DAYS=1825
LGPD_RETENTION_SPDATA_ESPELHO_DAYS=730
LGPD_RETENTION_BATCH_SIZE=500
```

Regras:

- BACKUP_AGE_RECIPIENT contém somente o destinatário público;
- nunca configurar AGE_IDENTITY_FILE ou a chave privada na VPS de produção;
- usar caminho absoluto para BACKUP_DIR;
- preferir volume ou armazenamento externo à VPS, com cópia criptografada e política de imutabilidade, para não manter banco e única cópia de recuperação no mesmo domínio de falha;
- aplicar 0700 ao diretório e 0600 aos arquivos;
- manter .env fora do Git e limitar sua leitura;
- não imprimir o ambiente completo durante diagnóstico;
- não usar credenciais na linha de comando fora do contêiner quando puderem aparecer no histórico ou na lista de processos.

Os equivalentes em dias 1825 e 730 operacionalizam, respectivamente, os prazos de 5 e 2 anos na configuração atual. Qualquer mudança nesses valores exige o procedimento de revisão e aprovação da Seção 18.

Por padrão, os scripts leem o .env da raiz. Um arquivo operacional em local protegido pode ser indicado sem revelar seu conteúdo:

```
ENV_FILE=/etc/sistema-clinico-mvp/backup.env \
COMPOSE_ENV_FILE=/opt/sistema-clinico-mvp/.env \
./scripts/backup_mysql_encrypted.sh
```

Preparação do diretório:

```
sudo install -d -m 0700 -o root -g root /var/backups/sistema-clinico-mvp/mysql
```

9. Backup MySQL criptografado

9.1 Interface operacional dos scripts

Os caminhos padronizados são:

- scripts/backup_mysql_encrypted.sh para geração, checksum e retenção do backup;
- scripts/restore_mysql_encrypted.sh para validação e restauração controlada.

Consultar a interface implantada antes do uso:

```
./scripts/backup_mysql_encrypted.sh --help
./scripts/restore_mysql_encrypted.sh --help
```

O script de backup não possui modo de simulação: sua execução gera um backup real e, após a publicação bem-sucedida do novo arquivo, aplica a retenção configurada aos backups anteriores. Por isso, deve ser testado primeiro em ambiente controlado e com diretório dedicado.

9.2 Execução do backup

Com o .env padrão da raiz:

```
cd /opt/sistema-clinico-mvp
./scripts/backup_mysql_encrypted.sh
```

Com arquivo de ambiente operacional protegido:

```
cd /opt/sistema-clinico-mvp
ENV_FILE=/etc/sistema-clinico-mvp/backup.env \
COMPOSE_ENV_FILE=/opt/sistema-clinico-mvp/.env \
./scripts/backup_mysql_encrypted.sh
```

O resultado esperado é um par de arquivos com permissões restritas:

```
sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age
sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age.sha256
```

O script executa mysqldump no serviço mysql, comprime com gzip, criptografa com o destinatário público age, calcula SHA-256 e elimina backups fora da retenção de 30 dias. Não deve existir arquivo .sql em claro no diretório de destino.

9.3 Garantias esperadas na geração

O script padronizado deve ser utilizado em vez de pipelines manuais. A operação deve manter as seguintes garantias:

- mysqldump consistente por --single-transaction, sem persistência de SQL em claro;
- compressão por gzip e criptografia por age em fluxo;

- arquivo temporário restrito e publicação somente após sucesso do pipeline;
- confirmação de arquivo não vazio;
- geração de checksum SHA-256 associado ao nome do backup;
- permissões 0600 nos artefatos e 0700 no diretório;
- remoção conjunta do backup e checksum vencidos;
- preservação dos backups anteriores quando a nova geração falhar.

A eliminação dos arquivos fora da retenção de 30 dias somente pode ocorrer depois de o novo backup ser publicado com sucesso. Uma execução que falhe deve retornar código diferente de zero e gerar alerta operacional.

10. Validação dos backups e checksum

10.1 Validação diária na VPS

A VPS valida presença, tamanho e checksum do arquivo criptografado, sem acesso à chave privada:

```
BACKUP_DIR=/var/backups/sistema-clinico-mvp/mysql
BACKUP_NAME=sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age

test -s "$BACKUP_DIR/$BACKUP_NAME"
(
  cd "$BACKUP_DIR"
  sha256sum -c "${BACKUP_NAME}.sha256"
)
```

O checksum deve ser calculado após o fechamento do arquivo. A validação de checksum comprova integridade binária em relação ao momento de geração, mas não substitui o teste de descriptografia e restauração.

10.2 Validação criptográfica fora da VPS

Em ambiente autorizado que tenha acesso temporário à identidade privada:

```
BACKUP_DIR=/secure/restore-input
BACKUP_NAME=sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age
AGE_IDENTITY_FILE=/secure/keys/medsystem-backup.agekey

(
  cd "$BACKUP_DIR"
  sha256sum -c "${BACKUP_NAME}.sha256"
)
age -d -i "$AGE_IDENTITY_FILE" "$BACKUP_DIR/$BACKUP_NAME" | gzip -t
```

Nenhum conteúdo descriptografado deve ser direcionado para log ou arquivo temporário sem necessidade formal e proteção equivalente.

11. Restauração

11.1 Regras gerais

- restauração ordinária deve ocorrer em ambiente isolado;
- restauração em produção exige incidente ou mudança aprovada pelo Controlador e pela TI responsável;
- integrações externas devem permanecer desabilitadas durante o teste;
- a identidade privada deve ser disponibilizada apenas durante a janela autorizada e removida ao final;
- a restauração não deve usar uma base com acesso de usuários finais;
- o backup e o checksum devem ser validados antes de qualquer escrita;
- a TI deve registrar qual backup, qual ambiente, operador, resultado e duração, sem registrar dados clínicos.

11.2 Dry-run de restauração

O dry-run valida checksum, descryptografia e compactação, sem enviar SQL ao MySQL:

```
set -euo pipefail

BACKUP_DIR=/secure/restore-input
BACKUP_NAME=sistema_clinico_mysql_YYYYMMDDTHMMSSZ.sql.gz.age
AGE_IDENTITY_FILE=/secure/keys/medsystem-backup.agekey

(
  cd "$BACKUP_DIR"
  sha256sum -c "${BACKUP_NAME}.sha256"
)
age -d -i "$AGE_IDENTITY_FILE" "$BACKUP_DIR/$BACKUP_NAME" | gzip -t
```

11.3 Execute de restauração

Executar exclusivamente no projeto Docker do ambiente isolado, configurado com banco próprio e sem conectividade com integrações de produção. O modo interativo exige digitar RESTAURAR:NOME_DO_BANCO, conforme o destino exibido:

```
cd /opt/sistema-clinico-mvp-restore-test
docker compose up -d mysql
docker compose exec -T mysql sh -c 'mysqladmin ping -h 127.0.0.1 -uroot -p"$MYSQL_ROOT_PASSWORD"'
AGE_IDENTITY_FILE=/secure/keys/medsystem-backup.agekey \
./scripts/restore_mysql_encrypted.sh \
/secure/restore-input/sistema_clinico_mysql_YYYYMMDDTHMMSSZ.sql.gz.age
```

Para uma execução não interativa previamente aprovada, a confirmação deve ser explícita no ambiente efêmero do processo e nunca armazenada no .env:

```
cd /opt/sistema-clinico-mvp-restore-test
AGE_IDENTITY_FILE=/secure/keys/medsystem-backup.agekey \
RESTORE_CONFIRM=RESTAURAR:sistema_clinico_mvp \
./scripts/restore_mysql_encrypted.sh \
/secure/restore-input/sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age
```

O script informa que a restauração pode substituir dados e não possui rollback automático. Uma falha de pipeline pode deixar o banco parcialmente alterado; por isso, o destino deve estar vazio ou ser descartável no teste isolado.

Após o restore, validar a estrutura e contagens agregadas das tabelas essenciais. Não copiar amostras identificáveis para tickets ou evidências.

```
docker compose exec -T mysql sh -c \
'exec mysql -uroot -p"$MYSQL_ROOT_PASSWORD" "$MYSQL_DATABASE" -e "SHOW TABLES; SELECT COUNT(*) AS
total_atendimentos FROM atendimentos; SELECT COUNT(*) AS total_auditorias FROM auditorias;"'
```

Ao encerrar, destruir volumes e arquivos temporários somente do ambiente isolado, depois de confirmar o caminho e o projeto Docker:

```
cd /opt/sistema-clinico-mvp-restore-test
docker compose down -v
```

12. Agendamento por cron

O backup deve ser executado diariamente em horário aprovado pela operação. Exemplo de agendamento às 02:15, usando caminho absoluto e encaminhando a saída ao log do sistema:

```
15 2 * * * cd /opt/sistema-clinico-mvp && /usr/bin/env bash -c 'set -o pipefail;
ENV_FILE=/etc/sistema-clinico-mvp/backup.env COMPOSE_ENV_FILE=/opt/sistema-clinico-mvp/.env
./scripts/backup_mysql_encrypted.sh 2>&1 | /usr/bin/logger -t sistema-clinico-backup'
```

Regras para o cron:

- instalar somente depois de o script existir, passar por revisão e concluir teste manual;
- não incluir senha, chave privada ou conteúdo do .env na linha do cron;
- conferir o fuso do host e manter timestamps de arquivos em UTC;
- alertar quando o comando retornar código diferente de zero;
- monitorar ausência de backup válido dentro da janela diária esperada;
- não executar retenção de arquivos se a geração ou validação do novo backup falhar;
- revisar o cron após mudanças de caminho, usuário, Docker ou sistema operacional.

O descarte das tabelas não deve ser automatizado por cron nesta versão. O --execute exige o hash de um dry-run revisado, referência de backup válido, referência da aprovação, operador responsável e confirmação de consulta às preservações legais. Enquanto não existir um mecanismo institucional de legal hold e aprovação eletrônica, a execução permanece manual, em janela aprovada.

13. Rotação dos logs Docker

A política técnica é 10x10MB: até dez arquivos de 10 MB por contêiner. Esse mecanismo limita ocupação em disco, mas não estabelece retenção em dias. Em sistemas com maior volume, o período coberto será menor; em sistemas com menor volume, poderá ser maior.

Configuração de referência a ser aplicada e validada para todos os serviços relevantes do Compose:

```
x-logging: &default-logging
  driver: json-file
  options:
    max-size: "10m"
    max-file: "10"

services:
  backend:
    logging: *default-logging
```

O mesmo bloco logging deve ser associado aos demais serviços aplicáveis. Após recriar os contêineres, validar a configuração efetiva:

```
docker compose ps -q | xargs -r docker inspect --format '{{.Name}} {{json .HostConfig.LogConfig}}'
```

Logs não devem conter senhas, tokens, chaves, strings de conexão, dumps, payloads clínicos completos ou dados pessoais além do estritamente necessário para diagnóstico autorizado.

14. Retenção no MySQL: dry-run e execute

14.1 Regras de segurança

1. Confirmar backup válido do mesmo ciclo operacional.
2. Confirmar inexistência de preservação legal ou incidente que suspenda o descarte.
3. Executar o dry-run e anexar apenas contagens à mudança.
4. Verificar dependências da tabela MED_SPDATA_ATENDIMENTOS.
5. Interromper se a quantidade ou o comportamento divergirem do esperado.
6. Executar em janela aprovada e, para volumes altos, processar em lotes.
7. Registrar as contagens eliminadas e o resultado final.
8. Nunca adicionar tabelas clínicas ao comando genérico de retenção.

14.2 Dry-run

O comando abaixo contabiliza candidatos e elegíveis, informa quantos registros estão protegidos por referências conhecidas e não altera o banco:

```
cd /opt/sistema-clinico-mvp
docker compose exec -T backend flask lgpd-retencao --dry-run
```

O resultado deve ser anexado à mudança operacional, incluindo o Hash do plano. Registros reportados em `protegidos_por_vinculo` permanecem preservados. Como os espelhos são apenas monitorados nesta versão, esses vínculos não impedem a limpeza das tabelas operacionais; qualquer vínculo futuro em regra destrutiva deve bloquear a execução. Não é permitido remover vínculos, excluir `MED_ATENDIMENTOS` ou usar cascata como atalho para tornar um espelho elegível.

14.3 Execute

Depois da aprovação do `dry-run` e da confirmação de um backup válido no mesmo ciclo, informe todas as referências obrigatórias:

```
cd /opt/sistema-clinico-mvp
docker compose exec -T backend flask lgpd-retencao --execute \
  --plan-hash HASH_SHA256_DO_DRY_RUN \
  --plan-reference REFERENCIA.UTC_DO_DRY_RUN \
  --backup-reference sistema_clinico_mysql_YYYYMMDDTHHMMSSZ.sql.gz.age \
  --approval-reference CHANGE-1234 \
  --operator conta-tecnica-responsavel \
  --confirm-no-legal-hold
```

O comando recalcula o plano usando a mesma referência UTC, compara o conjunto exato de IDs elegíveis e aborta se o hash divergir, se o plano tiver mais de 24 horas, se houver qualquer vínculo protegido ou se faltar uma referência. Quando aprovado, processa exclusões em lotes, dentro de transação, e registra hash, backup, aprovação, operador e contagens na auditoria. Nesta versão, somente logs de integração, filas terminais e auditorias vencidas são eliminados; os espelhos SPData aparecem no `dry-run`, mas permanecem preservados. A lista de tabelas-alvo nunca inclui Atendimento, Anamnese, Evolução/versões, Diagnóstico, Prescrição, Solicitação de Exame ou Documento Médico.

Após o `execute`, repetir o `dry-run`. O resultado esperado para registros elegíveis é zero. Registros protegidos por referência podem permanecer e devem ser tratados como retenção justificada por integridade, nunca eliminados por ampliação improvisada do comando.

15. Teste trimestral de restauração

Uma vez por trimestre, a TI deve comprovar que os backups são utilizáveis. O teste deve:

1. selecionar um backup válido dentro da janela de 30 dias, alternando amostras recentes e mais antigas ainda retidas;
2. copiar o backup criptografado e o checksum por canal autorizado;
3. preparar ambiente isolado, sem usuários finais e sem acesso às integrações SPDATA/Firebird, BioData/SQL Server, TTS ou outros serviços externos;
4. disponibilizar temporariamente a chave privada por meio seguro;
5. executar o `dry-run` de checksum, descriptografia e compactação;

6. restaurar o banco por streaming, sem dump SQL persistente;
7. validar estrutura, tabelas esperadas e contagens agregadas;
8. registrar tempo real, erros e resultado, sem prometer SLA não aprovado;
9. destruir volumes, arquivos temporários e credenciais do ambiente de teste;
10. registrar evidência e plano de correção quando o resultado não for satisfatório.

O teste não deve gerar telas, relatórios ou tickets com dados identificáveis de pacientes. O acesso aos dados restaurados deve ser limitado aos profissionais autorizados para a finalidade do teste.

16. Resposta a falhas e exceções

Evento	Ação imediata	Escalonamento e continuidade
Falha no mysqldump	Marcar execução como falha, preservar backups anteriores e coletar erro técnico sanitizado	Acionar TI; investigar saúde do MySQL, espaço e permissões.
Falha na criptografia age	Não aceitar o arquivo como backup; impedir a limpeza dos anteriores	Verificar destinatário público e versão do age; não transferir chave privada para a VPS.
Arquivo vazio ou checksum divergente	Isolar o arquivo, impedir restauração e retenção dos backups anteriores	Gerar novo backup e investigar disco, transferência ou corrupção.
Ausência de backup válido na janela diária	Emitir alerta e priorizar nova execução	Comunicar responsável de TI e registrar indisponibilidade da proteção.
Falta de espaço	Suspender operação destrutiva e evitar remoção não aprovada	Liberar espaço por procedimento seguro ou ampliar capacidade; não apagar backups fora da regra.
Perda da chave privada	Suspender alegação de recuperabilidade dos backups afetados	Comunicar Controlador e DPO, avaliar impacto e executar plano de recuperação/rotação.
Suspeita de exposição da chave	Restringir acessos e preservar evidências	Tratar como potencial incidente de segurança e avaliar notificações cabíveis.
Falha de restauração	Manter produção inalterada e preservar evidências técnicas	Corrigir causa e repetir o teste; elevar risco ao Controlador e DPO.
Dry-run com volume inesperado	Não executar o descarte	Revisar datas, fuso, regra, versão do banco e preservações.
Bloqueio referencial em espelho	Não remover vínculo nem registro clínico	Abrir mudança de correção estrutural e manter o dado até decisão aprovada.
Falha durante descarte	Confirmar ROLLBACK ou estado final e interromper novas tentativas	Comparar contagens, revisar transação e registrar incidente operacional.
Ordem de preservação	Suspender somente o descarte abrangido e identificar o escopo	Controlador e DPO documentam início, motivo, responsável e encerramento da preservação.

Uma falha de backup não autoriza retenção indefinida silenciosa nem descarte antecipado. A exceção deve ser registrada, possuir responsável, prazo de correção e aprovação compatível com o risco.

17. Evidências e auditoria operacional

Para cada execução relevante, manter registro com:

- identificador da mudança, chamado ou execução;
- data e hora UTC de início e fim;
- ambiente e host lógico, sem expor IP privado desnecessário;
- operador ou conta técnica responsável;
- versão do script ou hash do artefato executado;
- nome do backup, tamanho e SHA-256;
- resultado de checksum e, quando aplicável, descriptografia;
- contagens agregadas do dry-run e do execute por tabela;
- confirmação de que tabelas clínicas protegidas não fizeram parte do descarte;
- resultado do teste trimestral e tempo efetivamente observado;
- falhas, exceções, aprovações e ações corretivas;
- confirmação de destruição do ambiente isolado.

As evidências não devem conter senhas, chaves, tokens, conteúdo do .env, dump SQL, payloads de integração, textos clínicos, CPF, nome de paciente ou amostras de prontuário. O acesso deve ser restrito e rastreável.

Em caso de restauração de produção após um descarte formal, a TI deve verificar se o backup reintroduziu dados anteriormente eliminados e reaplicar, de forma controlada e auditável, as decisões de descarte ainda válidas.

18. Revisão e aprovação dos prazos

Os prazos devem ser revisados no mínimo anualmente e sempre que ocorrer:

- mudança legal, regulatória ou de orientação da autoridade competente;
- alteração das finalidades ou categorias de dados;
- inclusão de nova integração, tabela, ambiente ou fornecedor;
- mudança relevante na arquitetura de backup ou armazenamento;
- incidente de segurança ou falha de recuperação;
- solicitação dos responsáveis jurídicos, assistenciais, do Controlador ou do DPO;
- constatação de que o prazo é tecnicamente inexequível ou incompatível com integridade referencial.

Procedimento de revisão:

1. TI apresenta inventário atualizado, volume, dependências e capacidade.
2. Área de negócio e responsáveis assistenciais confirmam finalidade e necessidade.
3. Jurídico/regulatório avalia obrigações de guarda, defesa de direitos e restrições ao descarte.
4. DPO emite parecer de proteção de dados e registra riscos.
5. Controlador aprova, rejeita ou solicita ajustes.
6. TI implementa a mudança em ambiente de teste, executa dry-run e documenta o resultado.
7. A ativação em produção ocorre por mudança aprovada, com data de vigência e plano de reversão.
8. A nova versão é incluída no histórico de revisão.

Nenhum prazo pode ser reduzido ou ampliado apenas por conveniência técnica. Alterações devem considerar simultaneamente minimização, continuidade assistencial, obrigações de guarda, exercício regular de direitos e segurança.

19. Checklist operacional

19.1 Diário — backup

- ☐ Serviço MySQL saudável.
- ☐ Espaço disponível verificado.
- ☐ Destinatário público age configurado; chave privada ausente da VPS.
- ☐ Backup executado sem arquivo SQL persistente.
- ☐ Arquivo criptografado não vazio.
- ☐ SHA-256 criado e validado.
- ☐ Retenção de 30 dias executada somente após sucesso do novo backup.
- ☐ Código de saída e alerta verificados.
- ☐ Evidência registrada sem dados sensíveis.

19.2 Periódico — retenção no banco

- ☐ Prazos aprovados e preservações consultadas.
- ☐ Backup válido concluído.
- ☐ Dry-run executado e contagens revisadas.
- ☐ Bloqueadores de MED_SPDATA_ATENDIMENTOS iguais a zero.
- ☐ Apenas logs_integracao, fila terminal, auditorias e espelhos incluídos.
- ☐ Atendimento e dados clínicos excluídos do escopo do job.
- ☐ Execute realizado em janela aprovada.
- ☐ Dry-run repetido após a execução.
- ☐ Contagens e exceções registradas.

19.3 Mensal — infraestrutura

- ☐ Cron existente e executando no horário esperado.
- ☐ Permissões do diretório e arquivos revisadas.
- ☐ Rotação Docker confirmada como 10x10MB.
- ☐ Crescimento do volume e falhas analisados.
- ☐ Acessos administrativos e custódia da chave revisados.
- ☐ Scripts e documentação continuam coerentes.

19.4 Trimestral — restauração

- ☐ Backup e checksum selecionados.

- ☐ Ambiente isolado e integrações externas bloqueadas.
- ☐ Chave privada disponibilizada temporariamente por meio autorizado.
- ☐ Dry-run concluído.
- ☐ Restore concluído.
- ☐ Estrutura e contagens agregadas validadas.
- ☐ Resultado e duração registrados.
- ☐ Ambiente, volumes e materiais temporários destruídos.
- ☐ Chave removida do ambiente de teste.
- ☐ Falhas convertidas em plano de ação com responsável e prazo.

20. Histórico de revisão

Versão	Data	Descrição	Autor/área	Aprovação
1.0	13/08/2026	Emissão inicial da política técnico-operacional de retenção, descarte e backup.	Documentação técnica	Pendente de Controlador, DPO e validação jurídica/regulatória

Registro de aprovação

Papel	Nome	Decisão	Data	Referência da evidência
Controlador ou representante autorizado	A preencher	A preencher	A preencher	A preencher
Encarregado/DPO	A preencher	Parecer a preencher	A preencher	A preencher
Jurídico/regulatório	A preencher	Validação a preencher	A preencher	A preencher
Responsável assistencial	A preencher	Validação a preencher	A preencher	A preencher
Tecnologia da Informação	A preencher	Aceite operacional a preencher	A preencher	A preencher

Condição de vigência: esta política somente deve orientar automações destrutivas em produção após o preenchimento das aprovações, a implementação dos controles técnicos pendentes e a conclusão bem-sucedida dos testes de backup, dry-run, descarte e restauração isolada.